

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN



TIỂU LUẬN CUỐI KÌ
MÔN: BẢO MẬT TRONG IOT

**ĐỀ TÀI: CHECKLIST KIỂM TRA BẢO MẬT THIẾT BỊ IoT
TRƯỚC TRIỂN KHAI**

Lớp học phần	253INT441001
Giảng viên hướng dẫn	Hồ Nhật Minh
Sinh viên	Nguyễn Anh Hoàng
MSSV	231A011173
Link repo GitHub	https://github.com/hoangnguyen0/IoT-Security
Ngày nộp	31/07/2026

Thành Phố Hồ Chí Minh - 2026

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN**



TIÊU LUẬN CUỐI KÌ

MÔN: BẢO MẬT TRONG IOT

**ĐỀ TÀI: CHECKLIST KIỂM TRA BẢO MẬT THIẾT BỊ IoT
TRƯỚC TRIỂN KHAI**

**Giảng viên hướng dẫn: Hồ Nhật Minh
Sinh viên thực hiện: Nguyễn Anh Hoàng
MSSV: 231A011173
Lớp học phần: 253INT441001**

Thành Phố Hồ Chí Minh - 2026

MỤC LỤC

CAM KẾT AN TOÀN VÀ HỌC THUẬT	i
LỜI CẢM ƠN	ii
DANH MỤC TỪ VIẾT TẮT	iii
CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.2. Phát biểu vấn đề bảo mật	1
1.3. Mục tiêu	2
1.4. Đối tượng, phạm vi và giới hạn pháp lý	2
1.5. Sản phẩm dự kiến	2
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN.....	3
2.1. Kiến trúc, giao thức hoặc công nghệ nền Hệ thống IoT trong bài được cấu trúc theo 3 lớp logic phần mềm:	3
2.2. Khái niệm bảo mật liên quan Tài sản cốt lõi là Credentials và Dữ liệu cảm biến.....	3
2.3. Chuẩn, công cụ và nguồn GitHub chính.....	3
2.4. Công trình và giải pháp liên quan.....	3
2.6. Tiểu kết Chương 2	4
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ	5
3.1. Phương pháp	5
3.2. Mô hình/kiến trúc đề xuất.....	5
3.3. Thành phần, phiên bản và mục đích	6
3.4. Quy trình thực hiện.....	6
3.5. Giới hạn an toàn và đạo đức	7
CHƯƠNG 4. TRIỂN KHAI VÀ SẢN PHẨM.....	8
4.1. Các bước cài đặt	8
4.2. Thành phần sản phẩm	8
4.3. Kịch bản kiểm thử	13
CHƯƠNG 5. KẾT QUẢ VÀ THẢO LUẬN	17
5.1. Phân tích Log Kịch bản 1 (Insecure)	17
5.2. Phân tích Log Kịch bản 2 (Secure).....	17
5.3. Bảng tổng hợp kết quả theo tiêu chí	18
5.4. Đối chiếu mục tiêu (Mục 1.3).....	18
5.5. Hạn chế	19
CHƯƠNG 6. ĐÁNH GIÁ BẢO MẬT	20
6.4. Ưu tiên biện pháp	21

6.5. Đánh giá sau xử lý	22
CHƯƠNG 7. KẾT LUẬN.....	23
7.1. Kết luận.....	23
7.2. Hướng phát triển.....	23
TÀI LIỆU THAM KHẢO.....	24

MỤC LỤC HÌNH ẢNH

Hình 3.1. Sơ đồ kiến trúc thử nghiệm, vùng tin cậy và dữ liệu nhạy cảm	6
Hình 5.1. Ảnh chụp Serial Monitor thật từ wokwi.com, Kịch bản 1: kết nối MQTT không TLS, không xác thực, publish plaintext.....	17
Hình 5.2. Ảnh chụp Serial Monitor thật từ wokwi.com, Kịch bản 2: kết nối MQTT qua TLS + xác thực, publish lặp lại ổn định.	17

MỤC LỤC BẢNG

Bảng 1.1: Mục tiêu của đề tài và sản phẩm minh chứng	2
Bảng 2.1 Chuẩn, công cụ và nguồn GitHub chính.....	3
Bảng 3.1 Thành phần, phiên bản và mục đích sử dụng trong hệ thống	6
Bảng 3.2 Quy trình thực hiện và cấu trúc mã nguồn thử nghiệm	7
Bảng 4.1 Thành phần các sản phẩm triển khai.....	8
Bảng 4.2: Checklist kiểm tra bảo mật (Phần cứng, Firmware, Mạng, Giao thức, API, Dữ liệu, Vận hành).....	13
Bảng 4.3: Các kịch bản kiểm thử (TC-01 đến TC-05).....	14
Bảng 4.4: Mẫu phiếu kiểm tra đã điền thử (Tiêu chí NW04)	16
Bảng 4.5: Bảng ưu tiên xử lý lỗi	16
Bảng 5.1: Bảng tổng hợp kết quả đánh giá theo từng tiêu chí	18
Bảng 5.2: Bảng đối chiếu mức độ hoàn thành mục tiêu	19
Bảng 6.1: Phân loại mức độ quan trọng của tài sản và dữ liệu	20
Bảng 6.2: Các mối đe dọa và lỗ hổng xác định (T-01 đến T-06).....	21
Bảng 6.3: Ma trận đánh giá rủi ro (R-01 đến R-06).....	21
Bảng 6.4: Bảng ưu tiên các biện pháp xử lý và cách xác minh.....	22

CAM KẾT AN TOÀN VÀ HỌC THUẬT

Tôi cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

Ngoài ra, tôi xác nhận có sử dụng công cụ AI để hỗ trợ các công việc như tìm ra sót lỗi, diễn đạt nội dung. Các công cụ này chỉ đóng vai trò hỗ trợ, toàn bộ nội dung đã được tôi xem xét khi đưa vào bài báo cáo. Tôi xin hoàn toàn chịu trách nhiệm về tính nguyên bản và độ chính xác học thuật của bài tiểu luận này.

Họ tên người cam kết:

Ngày cam kết:

Chữ ký:

LỜI CẢM ƠN

Lời đầu tiên, em xin gửi lời cảm ơn chân thành sâu sắc đến Th.S Hồ Nhật Minh đã tận tình giảng dạy, định hướng và cung cấp những kiến thức quý báu để em có thể hoàn thành tốt tiểu luận với đề tài “Checklist kiểm tra bảo mật thiết bị IoT trước triển khai”.

Quá trình thực hiện đề tài không chỉ giúp em hiểu rõ hơn về các rủi ro bảo mật IoT như MQTT, mà còn có cơ hội áp dụng trực tiếp các tiêu chuẩn bảo mật chuyên sâu từ dự án OWASP. Việc tự tay tái cấu trúc mã nguồn, khắc phục lỗi truyền tải dữ liệu Plaintext và triển khai xác thực an toàn trên nền tảng mô phỏng Wokwi là những trải nghiệm thực tiễn vô cùng giá trị cho định hướng phát triển sau này.

Mặc dù đã nỗ lực hoàn thiện đề tài để đáp ứng các tiêu chí đề ra, nhưng do giới hạn về mặt thời gian và môi trường giả lập (chưa thể đo lường độ trễ thực tế hay thực nghiệm các kỹ thuật khai thác bộ nhớ cấp thấp trên thiết bị vật lý), bài tiểu luận chắc chắn vẫn còn những thiếu sót. Em rất mong nhận được sự góp ý và đánh giá từ Thầy để tiếp tục nâng cấp, hoàn thiện giải pháp trong tương lai.

Một lần nữa, em xin chân thành cảm ơn!

DANH MỤC TỪ VIẾT TẮT

Từ viết tắt	Giải thích	Từ viết tắt	Giải thích
IoT	Internet of Things (Internet vạn vật)	MQTT	Message Queuing Telemetry Transport
TLS	Transport Layer Security	SSL	Secure Sockets Layer (tiền thân của TLS)
TCP	Transmission Control Protocol	WiFi	Wireless Fidelity
API	Application Programming Interface	OWASP	Open Web Application Security Project
ISVS	IoT Security Verification Standard (chuẩn OWASP)	ISTG	IoT Security Testing Guide (chuẩn OWASP)
FSTM	Firmware Security Testing Methodology (chuẩn OWASP)	ETSI	European Telecommunications Standards Institute
NIST	National Institute of Standards and Technology	CISA	Cybersecurity and Infrastructure Security Agency (Hoa Kỳ)
DDoS	Distributed Denial of Service	MITM	Man-in-the-Middle
DNS	Domain Name System	NVS	Non-Volatile Storage (bộ nhớ cấu hình trên ESP32)
mTLS	Mutual Transport Layer Security	CI/CD	Continuous Integration / Continuous Deployment
JSON	JavaScript Object Notation	CPU	Central Processing Unit
RAM	Random Access Memory	P / I / R	Probability / Impact / Risk score (ký hiệu dùng trong ma trận rủi ro, Chương 5)

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Mô hình phổ biến hiện nay tại các phòng lab, doanh nghiệp vừa và nhỏ và các dự án nông nghiệp/nhà thông minh là dùng vi điều khiển giá rẻ (ESP32) thu thập dữ liệu cảm biến (nhiệt độ, độ ẩm, chất lượng không khí...) và gửi lên nền tảng cloud qua giao thức MQTT/HTTP để giám sát, cảnh báo hoặc điều khiển thiết bị chấp hành từ xa. Áp lực về chi phí và thời gian ra sản phẩm khiến nhiều đội phát triển bỏ qua bước xác minh bảo mật một cách hệ thống trước khi đưa hệ thống vào vận hành thực tế, khiến thiết bị mang theo sẵn các lỗi cấu hình cơ bản như tài khoản mặc định không đổi, kênh truyền không mã hoá hoặc firmware không kiểm soát cập nhật.

Hậu quả của việc bỏ qua bước kiểm tra này không dừng lại ở một thiết bị đơn lẻ. Cuối năm 2016, mạng botnet Mirai đã khai thác một danh sách khoảng 60 cặp tài khoản/mật khẩu mặc định thường gặp trên thiết bị IoT (chủ yếu router và camera giám sát) để chiếm quyền hơn 600.000 thiết bị, tạo ra các đợt tấn công từ chối dịch vụ với lưu lượng đỉnh vượt 1 Tbps, khiến hàng loạt dịch vụ lớn như GitHub, Twitter, Netflix và nhà cung cấp DNS Dyn bị gián đoạn diện rộng. Đối tượng chịu ảnh hưởng không chỉ là chủ sở hữu thiết bị mà còn là các dịch vụ Internet không liên quan, trong khi đơn vị triển khai thiết bị phải gánh trách nhiệm pháp lý và uy tín khi sự cố xảy ra.

OWASP hiện đã cung cấp các tiêu chuẩn xác minh bảo mật IoT khá đầy đủ (ISVS, ISTG, FSTM), tuy nhiên các tài liệu này có quy mô lớn (ISVS gồm 165 yêu cầu) và không được trình bày dưới dạng công cụ gọn nhẹ, dễ áp dụng cho một đợt kiểm tra nhanh trước triển khai của một nhóm nhỏ. Đây là lý do đề tài được thực hiện: chuyển hoá các tiêu chuẩn mở của OWASP thành một checklist thực dụng, có cách kiểm tra và minh chứng cụ thể, phù hợp áp dụng ngay trong môi trường lab hoặc quy trình QA thực tế.

1.2. Phát biểu vấn đề bảo mật

Tài sản cần bảo vệ trong phạm vi đề tài gồm:

- (1) dữ liệu cảm biến và dữ liệu vận hành sinh ra từ thiết bị;
- (2) thông tin xác thực dùng để kết nối (WiFi, tài khoản MQTT, API key, chứng chỉ TLS);
- (3) quyền điều khiển thiết bị/thiết bị chấp hành;
- (4) tính sẵn sàng của dịch vụ broker/API;
- (5) uy tín cùng nghĩa vụ tuân thủ pháp lý của đơn vị triển khai.

Các mối đe dọa và lỗ hổng chính bám theo danh sách OWASP IoT Top 10 gồm: tài khoản/mật khẩu yếu hoặc mặc định, dịch vụ mạng không an toàn, giao diện hệ sinh thái (API/cloud/app) thiếu xác thực, thiếu cơ chế cập nhật firmware an toàn, sử dụng thành phần phần mềm lỗi thời, truyền và lưu trữ dữ liệu không mã hoá, và thiếu giám sát vận hành. Hậu quả tương ứng là bị chiếm quyền

điều khiển thiết bị, rò rỉ dữ liệu cảm biến/dữ liệu cá nhân, hoặc thiết bị bị lợi dụng làm botnet tấn công hạ tầng khác như minh họa ở sự cố Mirai.

Khoảng trống mà đề tài xử lý: hiện thiếu một bộ checklist rút gọn, bám sát các tiêu chuẩn OWASP nhưng đủ ngắn gọn, có gắn cách kiểm tra và minh chứng cụ thể theo từng tiêu chí, kèm thang ưu tiên xử lý rõ ràng, để một nhóm nhỏ có thể tự thực hiện một đợt xác minh bảo mật hoàn chỉnh trước khi cho phép thiết bị IoT go-live.

1.3. Mục tiêu

Mục tiêu	Mô tả	Sản phẩm minh chứng
MT-01	Checklist bảo mật ≥ 35 tiêu chí, bao phủ 7 nhóm theo Bảng 4.2	Bảng 4.2 (37 tiêu chí)
MT-02	Mẫu phiếu kiểm tra đã điền thử bằng dữ liệu thật	Mục 4.4
MT-03	Hướng dẫn sử dụng checklist 1 trang	Mục 4.4
MT-04	Bảng ưu tiên xử lý lỗi 3 mức	Mục 4.4
MT-05	Kiểm chứng thật $\geq 30\%$ tiêu chí bằng ảnh Serial Monitor Wokwi + lab MQTT cục bộ	Mục 5.1, 5.2 ($11/37 = 30\%$)

Bảng 1.1: Mục tiêu của đề tài và sản phẩm minh chứng

1.4. Đối tượng, phạm vi và giới hạn pháp lý

Đối tượng: thiết bị IoT dùng ESP32, giao thức MQTT, broker Mosquitto/Wokwi. Phạm vi: mô phỏng Wokwi (2 kịch bản mã nguồn thật, do sinh viên tự chạy) + lab Mosquitto cục bộ đối chiếu độc lập. Giới hạn pháp lý và đạo đức: không khai thác lỗ hổng hệ thống thật, không tấn công DDoS thật, không trích xuất firmware vật lý (không sở hữu thiết bị thật), không sử dụng dữ liệu cá nhân thật.

1.5. Sản phẩm dự kiến

Checklist đầy đủ 37 tiêu chí/7 nhóm đáp ứng yêu cầu tối thiểu 35 tiêu chí.

11/37 tiêu chí có kết quả kiểm chứng thật bằng ảnh Serial Monitor Wokwi (Mục 4.4, 5.1-5.2).

Mẫu phiếu kiểm tra, bảng ưu tiên xử lý lỗi, ma trận rủi ro T-01...T-06/R-01...R-06 (Mục 4.4, Chương 6).

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc, giao thức hoặc công nghệ nền Hệ thống IoT trong bài được cấu trúc theo 3 lớp logic phần mềm:

Lớp Firmware đảm nhiệm việc khởi tạo kết nối mạng (dùng thư viện mạng chuẩn hoặc bảo mật); Lớp Giao thức sử dụng MQTT để đóng gói và truyền tin qua WiFi ảo; Lớp Ứng dụng tiếp nhận Payload JSON từ cảm biến. Kiến trúc nền cốt lõi là giao thức MQTT: ở cấu hình mặc định (công 1883), giao thức này truyền tin dưới dạng văn bản thô (Plaintext), khiến toàn bộ Payload và thông tin đăng nhập dễ dàng bị đọc trộm trên đường truyền.

2.2. Khái niệm bảo mật liên quan Tài sản cốt lõi là Credentials và Dữ liệu cảm biến.

Mối đe dọa chính gồm Nghe lén (Sniffing) và Giả mạo thiết bị (Spoofing). Để kiểm soát, hệ thống bắt buộc triển khai hai khái niệm: Mã hóa đường truyền bằng TLS (Transport Layer Security) nhằm tạo đường hầm bảo mật chống MITM, và Xác thực danh tính (Authentication) qua Username/Password nhằm ngăn chặn các luồng đăng nhập ẩn danh trái phép vào máy chủ.

2.3. Chuẩn, công cụ và nguồn GitHub chính

STT	Chuẩn / Công cụ / Tài liệu	Đường dẫn (URL / GitHub)	Ngày
1	OWASP ISVS (IoT Security Verification Standard)	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	25/07/2026
2	OWASP ISTG (IoT Security Testing Guide)	https://github.com/OWASP/owasp-istg	25/07/2026
3	OWASP FSTM (Firmware Security Testing Methodology)	https://github.com/scriptingxss/owasp-fstm	25/07/2026
4	OWASP IoT Project	https://github.com/OWASP/www-project-internet-of-things	25/07/2026
5	Công cụ phân tích firmware (binwalk, firmwalker, strings, EMBA)	Tích hợp trong giai đoạn 3-6 của phương pháp OWASP FSTM	25/07/2026
6	Nền tảng Wokwi	wokwi.com	25/07/2026

Bảng 2.1 Chuẩn, công cụ và nguồn GitHub chính

2.4. Công trình và giải pháp liên quan

Ngoài các tiêu chuẩn của OWASP, một số khung đánh giá liên quan cũng được tham khảo để đối chiếu phạm vi: ETSI EN 303 645 (tiêu chuẩn châu Âu về bảo mật tối thiểu cho thiết bị IoT tiêu dùng) và NISTIR 8259 (hướng dẫn của NIST về năng lực bảo mật lõi cho thiết bị IoT) đều nhấn mạnh việc loại bỏ thông tin xác thực mặc định và bảo vệ kênh truyền trùng khớp với hai nhóm tiêu chí có mức ưu tiên cao nhất trong checklist của đề tài (Firmware và Giao thức). Về mặt minh họa

hậu quả thực tế, các phân tích hồi cứu về sự cố Mirai của Cloudflare và cảnh báo chính thức của CISA cung cấp dữ liệu định lượng (quy mô thiết bị bị chiếm quyền, lưu lượng tấn công) được đề tài trích dẫn tại Mục 1.1 và dùng làm căn cứ ước lượng mức độ ảnh hưởng trong ma trận rủi ro ở Chương 5.

2.6. Tiểu kết Chương 2

Chương 2 đã hệ thống hoá các khái niệm bảo mật và bốn tài liệu OWASP làm nền tảng lý thuyết cho đề tài, đồng thời xác lập mô hình kiến trúc tham chiếu 4 lớp dùng xuyên suốt các chương tiếp theo. Các nội dung này là cơ sở trực tiếp để xây dựng phương pháp thực hiện ở Chương 3 và checklist chi tiết ở Chương 4.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp

Quy trình xây dựng và kiểm chứng bộ Checklist bảo mật được thực hiện qua 7 bước tuần tự như sau:

Bước 1: Tổng hợp và chất lọc tiêu chuẩn: Đọc và tổng hợp yêu cầu từ các tiêu chuẩn OWASP ISVS (chương V2-V5), ISTG và FSTM. Rút trích các yêu cầu bảo mật cốt lõi, chỉ tập trung vào lớp phần mềm (Firmware), cấu hình mạng (Network) và giao thức truyền tải (Protocol).

Bước 2: Phân nhóm tiêu chí: Chia checklist thành các nhóm và soát bám sát theo các lớp cấu trúc logic của hệ thống mô phỏng (Mục 2.1), bao gồm: Firmware, Mạng, Giao thức và Dữ liệu.

Bước 3: Chi tiết hóa bộ Checklist: Với mỗi nhóm, xây dựng tối thiểu 5 tiêu chí kiểm tra bảo mật. Mỗi tiêu chí được chuẩn hóa gồm: Mã định danh, Mô tả, Mức ưu tiên và Ô trạng thái (Đạt/Chưa đạt/Không áp dụng).

Bước 4: Xây dựng thang đo ưu tiên: Thiết lập thang ưu tiên gồm 3 cấp độ (Bắt buộc trước triển khai, Nên có, Cải tiến sau) dựa trên mức độ ảnh hưởng của lỗi cấu hình mã nguồn và khả năng bị khai thác qua môi trường mạng.

Bước 5: Hoàn thiện phương pháp đo lường: Bổ sung cột “Cách kiểm tra” (ví dụ: đọc phân tích mã nguồn tĩnh, kiểm tra thư viện mạng) và cột “Minh chứng ví dụ” (Log console, Screenshot) cho từng tiêu chí.

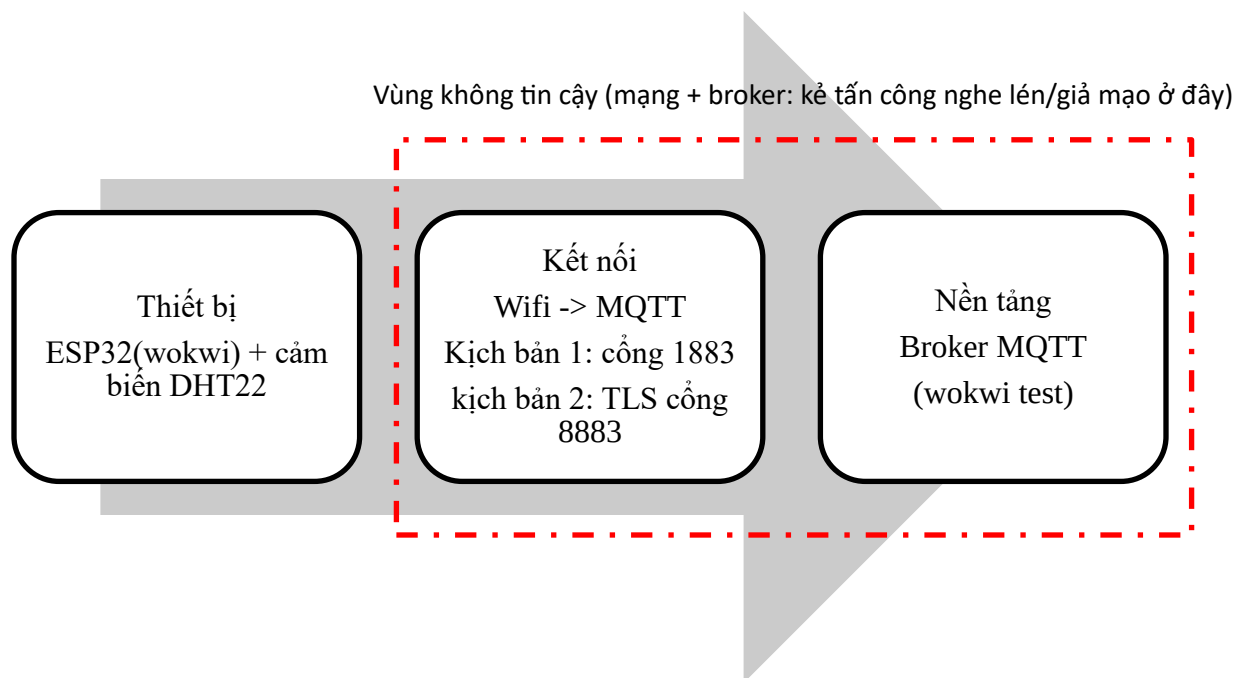
Bước 6: Kiểm chứng thực nghiệm trên Wokwi: Triển khai mô phỏng 2 kịch bản phần mềm tiêu biểu trên nền tảng Wokwi với ESP32 ảo để lấy minh chứng thực tế:

Kịch bản 1: Cấu hình mã nguồn lỗi (MQTT Plaintext không mã hoá, không yêu cầu mật khẩu).

Kịch bản 2: Mã nguồn đã khắc phục (Bọc gói tin bằng TLS qua cổng 8883, ép buộc xác thực bằng tài khoản).

Bước 7: Đánh giá rủi ro và đóng gói: Thực hiện phân tích log từ Bước 6 để đánh giá rủi ro (Chương 5). Tổng hợp toàn bộ thành báo cáo, phiếu checklist mẫu, bảng phân loại ưu tiên và hướng dẫn rà soát có thể tái sử dụng cho các dự án phần mềm IoT thực tế.

3.2. Mô hình/kiến trúc đề xuất



Hình 3.1. Sơ đồ kiến trúc thử nghiệm, vùng tin cậy và dữ liệu nhạy cảm

Vùng không tin cậy (đường đứt nét đỏ) bao gồm mạng và broker nơi kẻ tấn công có thể nghe lén (Kịch bản 1) hoặc cần vượt qua TLS+xác thực (Kịch bản 2). Dữ liệu nhạy cảm gồm: thông tin xác thực MQTT (hằng số tĩnh trong mã nguồn) và payload cảm biến JSON.

3.3. Thành phần, phiên bản và mục đích

Thành phần	Phiên bản	Mục đích	Ghi chú an toàn
Wokwi	bản web hiện hành	Mô phỏng ESP32+DHT22, chạy thật 2 kịch bản	Không dùng dữ liệu/mạng thật
Mosquitto	2.0.18	Broker MQTT cục bộ, đối chiếu độc lập	Chạy trên 127.0.0.1, không expose Internet
PubSubClient	2.8	Thư viện MQTT client cho ESP32	Thư viện mã nguồn mở, không sửa đổi
DHT sensor library	1.4.x	Đọc dữ liệu cảm biến DHT22 (giả lập)	Dữ liệu giả lập, không phải cảm biến thật

Bảng 3.1 Thành phần, phiên bản và mục đích sử dụng trong hệ thống

3.4. Quy trình thực hiện

Đường dẫn (trong repo nộp kèm)	Chức năng	Đường dẫn (trong repo nộp kèm)	Chức năng
src/kichban1-khong-an-toan/sketch.ino	Mã nguồn ESP32 kết nối MQTT	src/kichban1-khong-an-toan/sketch.ino	Mã nguồn ESP32 kết

	không TLS, không xác thực		nối MQTT không TLS, không xác thực
src/kichban2-da-khac-phuc/sketch.ino	Mã nguồn ESP32 kết nối MQTT qua TLS + xác thực username/password	src/kichban2-da-khac-phuc/sketch.ino	Mã nguồn ESP32 kết nối MQTT qua TLS + xác thực username/password
results/hinh-5-1-serial-kichban1.png	Ảnh chụp Serial Monitor thật, Kịch bản 1	results/hinh-5-1-serial-kichban1.png	Ảnh chụp Serial Monitor thật, Kịch bản 1
results/hinh-5-2-serial-kichban2.png	Ảnh chụp Serial Monitor thật, Kịch bản 2	results/hinh-5-2-serial-kichban2.png	Ảnh chụp Serial Monitor thật, Kịch bản 2
report/231A011173_NguyenAnhHoang_48_BaoCao.docx	Báo cáo chính (file này)	report/231A011173_NguyenAnhHoang_48_BaoCao.docx	Báo cáo chính (file này)

Bảng 3.2 Quy trình thực hiện và cấu trúc mã nguồn thử nghiệm

3.5. Giới hạn an toàn và đạo đức

Chỉ thử nghiệm trên broker do sinh viên tự dựng (Wokwi mô phỏng hoặc Mosquitto cục bộ 127.0.0.1); dữ liệu cảm biến giả lập; không tấn công DDoS thật; không phân tích firmware thương mại chưa được phép. Các tiêu chí không thể quan sát trong phạm vi mô phỏng (phần cứng vật lý, API/cloud, OTA) được ghi rõ “Ngoài phạm vi demo” thay vì suy diễn kết quả.

CHƯƠNG 4. TRIỂN KHAI VÀ SẢN PHẨM

4.1. Các bước cài đặt

Bước 1: Truy cập wokwi.com, tạo project ESP32 mới, nạp diagram.json (khai báo ESP32 + DHT22).

Bước 2: Cài thư viện qua Library Manager: PubSubClient, DHT sensor library, Adafruit Unified Sensor.

Bước 3: Dán mã nguồn Kịch bản 1 (src/kichban1-khong-an-toan/sketch.ino), nhấn Play, quan sát Serial Monitor.

Bước 4: Dán mã nguồn Kịch bản 2 (src/kichban2-da-khac-phuc/sketch.ino), nhấn Play, quan sát Serial Monitor.

Bước 5 (đối chiếu độc lập): cài Mosquitto cục bộ, lặp lại 2 kịch bản bằng mosquito_pub/sub để xác nhận kết quả không phụ thuộc riêng vào Wokwi.

4.2. Thành phần sản phẩm

Đường dẫn (trong repo nộp kèm)	Chức năng
src/kichban1-khong-an-toan/sketch.ino	Mã nguồn ESP32 kết nối MQTT không TLS, không xác thực
src/kichban2-da-khac-phuc/sketch.ino	Mã nguồn ESP32 kết nối MQTT qua TLS + xác thực username/password
results/hinh-5-1-serial-kichban1.png	Ảnh chụp Serial Monitor thật, Kịch bản 1
results/hinh-5-2-serial-kichban2.png	Ảnh chụp Serial Monitor thật, Kịch bản 2
report/231A011173_NguyenAnhHoang_DeTai48_TieuLuan_CuoiKy.docx	Báo cáo chính (file này)
references/	Danh sách tài liệu tham khảo đầy đủ

Bảng 4.1 Thành phần các sản phẩm triển khai

Mã tô đậm = 1 trong 11 tiêu chí đã kiểm chứng thật (Mục 4.4, 5.1-5.3); các mục không được tô đậm ngoài phạm vi demo/Không áp dụng, không được trình bày như đã kiểm chứng ở bất kỳ đâu khác trong báo cáo.

Mã	Ưu tiên	Tiêu chí	Cách kiểm tra	Trạng thái minh chứng
----	---------	----------	---------------	-----------------------

NHÓM: PHẦN CỨNG				
HW01	Bắt buộc	Cổng debug vật lý (UART/JTAG/SWD) bị vô hiệu hoá hoặc che phủ trên bản sản xuất	Dò chân bằng datasheet + đồng hồ đo, thử nối USB-TTL	Không đánh giá trên mô phỏng Wokwi (không có phần cứng vật lý)
HW02	Nên có	Có cơ chế phát hiện can thiệp vỏ máy (tamper-evident)	Kiểm tra thiết kế cơ khí/tem niêm phong	Không áp dụng cho mô phỏng
HW03	Bắt buộc	Không lưu khoá bí mật ở dạng rõ trên bộ nhớ ngoài có thể tháo rời	Đọc trực tiếp chip nhớ ngoài hoặc xem sơ đồ mạch	Không áp dụng cho mô phỏng
HW04	Nên có	Dùng Secure Element/TPM hoặc vùng OTP của SoC lưu khoá gốc	Đối chiếu datasheet SoC	ESP32 mô phỏng không có Secure Element thật
HW05	Cải tiến sau	Có nhãn/cảnh báo rủi ro khi tự ý can thiệp phần cứng	Kiểm tra tài liệu đi kèm sản phẩm	Không áp dụng cho mô phỏng
NHÓM: FIRMWARE				
FW01	Bắt buộc	Không còn tài khoản/mật khẩu mặc định của nhà sản xuất sau triển khai	Thủ đăng nhập bằng danh sách mật khẩu mặc định công khai	Kiểm chứng thật: Kịch bản 1, broker cho phép anonymous Chưa đạt (Mục 5.1)
FW02	Bắt buộc	Không hardcode tài khoản/mật khẩu/API key trong mã nguồn/firmware	strings/grep trên mã nguồn hoặc file .bin đã biên dịch	Kiểm chứng thật: sketch.ino Kịch bản 1 khai báo MQTT_USER/PASS trực tiếp Chưa đạt
FW03	Bắt buộc	Không hardcode khoá mã hoá/private key dùng chung toàn dòng sản phẩm	Rà soát mã nguồn tìm chuỗi PEM/BEGIN KEY	Kiểm chứng thật: không phát sinh trong 2 kịch bản (không dùng chứng chỉ client) N/A

FW04	Bắt buộc	Cập nhật firmware qua mạng (OTA) được ký số và xác minh trước khi flash	Kiểm tra quy trình OTA, thử flash firmware không có chữ ký hợp lệ	Ngoài phạm vi demo hiện tại cần lab riêng
FW05	Nên có	Hỗ trợ Secure Boot/Verified Boot	Kiểm tra cấu hình eFuse/bootloader của SoC	Ngoài phạm vi demo không bật trong bản mô phỏng Wokwi
FW06	Nên có	Không dùng thư viện/thành phần phần mềm đã biết lỗ hổng (CVE)	Đối chiếu phiên bản thư viện (PubSubClient, DHT...) với CVE công khai	Chưa thực hiện tra cứu CVE cụ thể trong phạm vi báo cáo
NHÓM: MẠNG				
NW01	Bắt buộc	Không mở cổng dịch vụ không cần thiết (telnet/ftp/debug) ra mạng	nmap quét cổng thiết bị	Không áp dụng cho mô phỏng Wokwi (không có địa chỉ IP công khai)
NW02	Bắt buộc	Toàn bộ traffic dữ liệu nhạy cảm được mã hoá (TLS/DTLS)	Bắt gói tin, kiểm tra payload có mã hoá hay không	Kiểm chứng thật: Chưa đạt (cổng 1883) / Đạt (cổng 8883 TLS) Mục 5.1-5.2
NW03	Nên có	Thiết bị được cô lập trong VLAN/mạng con riêng	Kiểm tra cấu hình switch/router, sơ đồ mạng	Ngoài phạm vi mô phỏng cần hạ tầng mạng thật
NW04	Bắt buộc	Không dùng giao thức truyền dữ liệu ở dạng plaintext cho dữ liệu nhạy cảm	Subscribe topic bằng client bất kỳ, xem có đọc được payload không	Kiểm chứng thật: Chưa đạt (Kịch bản 1) / Đạt (Kịch bản 2) Mục 5.1-5.2
NW05	Nên có	Có giới hạn tốc độ kết nối (rate limiting) chống quét/brute-force	Thử kết nối lặp lại nhanh, quan sát broker có chặn không	Chưa cấu hình trong lab/demo khuyến nghị bổ sung

NW06	Cải tiến sau	Giám sát lưu lượng bất thường ở tầng mạng	Thiết lập IDS/log giám sát	Ngoài phạm vi đề tài (thuộc nhóm giám sát vận hành nâng cao)
NHÓM: GIAO THỨC				
PR01	Bắt buộc	Kết nối MQTT bắt buộc xác thực, không cho phép anonymous	Thử kết nối không kèm username/password	Kiểm chứng thật: Chưa đạt (Kịch bản 1) / Đạt (Kịch bản 2) Mục 5.1-5.2
PR02	Bắt buộc	Chứng chỉ TLS của broker/server được client xác minh (không tắt kiểm tra CA)	Thử kết nối TLS không truyền CA hợp lệ hoặc tự ký sai	Kiểm chứng thật: Kịch bản 2 dùng setInsecure() Chưa đạt đầy đủ, chỉ chấp nhận trong môi trường lab (Mục 5.4)
PR03	Nên có	Áp dụng ACL theo topic thay vì một tài khoản dùng chung	Kiểm tra file ACL của broker, thử publish ngoài phạm vi được cấp	Demo dùng 1 tài khoản chung cần bổ sung ACL nếu áp dụng thực tế
PR04	Nên có	Có cơ chế chống replay attack (nonce/timestamp) cho lệnh điều khiển	Gửi lại (replay) một gói tin đã bắt được, quan sát phản ứng thiết bị	Ngoài phạm vi demo (sketch chỉ gửi cảm biến 1 chiều, không có lệnh điều khiển)
PR05	Cải tiến sau	Giới hạn kích thước payload và tần suất publish	Kiểm tra cấu hình message_size_limit của broker	Chưa cấu hình trong lab ghi nhận khuyến nghị
NHÓM: API/CLOUD				
AC01	Bắt buộc	API backend yêu cầu xác thực cho mọi endpoint truy xuất dữ liệu thiết bị	Gọi thử endpoint không kèm token	Ngoài phạm vi demo (đề tài không xây dựng lớp API/cloud riêng)
AC02	Bắt buộc	Không để lộ API key/token trong ứng dụng	Giải nén APK/đọc mã nguồn client tìm chuỗi key	Ngoài phạm vi demo

		di động/mã nguồn phía client		
AC03	Nên có	Phân quyền theo vai trò (RBAC) giữa người dùng và quản trị	Kiểm tra ma trận quyền trên hệ thống thật	Ngoài phạm vi demo
AC04	Nên có	API có giới hạn tốc độ gọi và ghi log truy cập	Gửi request dồn dập, kiểm tra log/HTTP 429	Ngoài phạm vi demo
AC05	Cải tiến sau	Kiểm thử API định kỳ bằng công cụ tự động	Chạy OWASP ZAP/Postman security test	Ngoài phạm vi demo
NHÓM: DỮ LIỆU				
DT01	Bắt buộc	Dữ liệu cảm biến/dữ liệu cá nhân được mã hoá khi lưu trữ	Kiểm tra cấu hình mã hoá tại nơi lưu trữ (DB/broker persistence)	Broker lab dùng bộ nhớ tạm, không bật persistence không đánh giá được
DT02	Bắt buộc	Có chính sách thu thập dữ liệu tối thiểu (data minimization)	Đối chiếu dữ liệu thực thu thập với nhu cầu nghiệp vụ	Kiểm chứng thật: demo chỉ gửi nhiệt độ/độ ẩm giả lập Đạt ở mức nguyên tắc thiết kế
DT03	Nên có	Có cơ chế xoá/ẩn danh dữ liệu khi ngừng sử dụng thiết bị	Kiểm tra quy trình off-boarding thiết bị	Ngoài phạm vi demo
DT04	Nên có	Sao lưu dữ liệu định kỳ và kiểm tra khả năng khôi phục	Thử khôi phục từ bản sao lưu	Ngoài phạm vi demo
DT05	Bắt buộc	Khoá mã hoá được quản lý qua KMS/HSM hoặc provisioning an toàn, không đặt cứng trong file cấu hình tĩnh	Kiểm tra quy trình cấp phát khoá	Kiểm chứng thật: MQTT_USER/PASS trong sketch.ino là hằng số tĩnh ở cả 2 kịch bản. Chưa đạt chuẩn production

NHÓM: VẬN HÀNH				
OP01	Bắt buộc	Có quy trình phản hồi sự cố khi phát hiện thiết bị bị xâm nhập	Kiểm tra tài liệu quy trình IR	Ngoài phạm vi demo kỹ thuật - đề xuất mẫu quy trình ở Mục 4.4
OP02	Nên có	Có giám sát/log tập trung cho kết nối và lỗi xác thực bất thường	Kiểm tra hệ thống log tập trung (SIEM/ELK)	Kiểm chứng một phần: log broker cục bộ trong lab dùng làm minh họa tối thiểu (Mục 5.1-5.2)
OP03	Nên có	Có quy trình vá lỗi/thông báo lỗ hổng (patch management)	Kiểm tra cam kết SLA vá lỗi của nhà cung cấp	Ngoài phạm vi demo
OP04	Cải tiến sau	Đào tạo người vận hành đổi mật khẩu mặc định, cập nhật firmware	Kiểm tra tài liệu hướng dẫn người dùng	Ngoài phạm vi demo
OP05	Bắt buộc	Có phiếu go/no-go trước triển khai; không triển khai khi còn tiêu chí Bắt buộc ở trạng thái Chưa đạt	Đối chiếu toàn bộ checklist trước ngày go-live	Kiểm chứng thật: áp dụng trực tiếp - xem khuyến nghị go/no-go ở Mục 5.3

Bảng 4.2: Checklist kiểm tra bảo mật (Phần cứng, Firmware, Mạng, Giao thức, API, Dữ liệu, Vận hành)

4.3. Kịch bản kiểm thử

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi
TC-01	Xác nhận Kịch bản 1 kết nối không xác thực	sketch.ino KB1, broker Wokwi test	Chạy Play, đọc Serial Monitor	Log hiện “KHONG TLS, KHONG AUTH”
TC-02	Xác nhận Kịch bản 1 gửi dữ liệu dạng rõ	sketch.ino KB1	Đọc dòng Publish trong Serial Monitor	Payload JSON đọc được nguyên văn
TC-03	Xác nhận Kịch bản 2	sketch.ino KB2, broker Wokwi test	Chạy Play, đọc Serial Monitor	Log hiện “qua TLS + xác thực”

	bắt buộc TLS + xác thực			
TC-04	Đối chiếu độc lập ngoài Wokwi (không anonymous)	Broker Mosquitto cục bộ, allow_anonymous true	mosquitto_pub không kèm user/pass	Kết nối bị từ chối sau khi cấu hình lại yêu cầu auth
TC-05	Rà soát mã nguồn tìm credential hardcoded	sketch.ino KB1 và KB2	grep MQTT_USER/MQTT_PASSWORD trong 2 file	Tìm thấy hằng số tĩnh ở cả 2 file

Bảng 4.3: Các kịch bản kiểm thử (TC-01 đến TC-05)

4.4 Hướng dẫn sử dụng

1. Cấu trúc bộ mã nguồn cung cấp Bộ mã nguồn kiểm thử được đóng gói trong thư mục gốc wokwi-demo, bao gồm tệp README.md và src (2 kịch bản chính được nén trong wokwi-demo.zip):

Thư mục kichban1-khong-an-toan: Chứa mã nguồn mô phỏng cấu hình mạng mặc định, thiếu bảo mật (giao tiếp MQTT dạng Plaintext, không xác thực).

Thư mục kichban2-da-khac-phuc: Chứa mã nguồn đã được tinh chỉnh, tuân thủ checklist bảo mật (áp dụng mã hóa TLS và xác thực tài khoản).

Bên trong mỗi thư mục kịch bản đều chứa 3 tệp tin cấu hình tiêu chuẩn của hệ thống Wokwi:

sketch.ino: Chứa toàn bộ mã nguồn C/C++ xử lý logic mạng và giao thức MQTT.

diagram.json: Tệp định dạng JSON chứa sơ đồ đấu nối và khai báo linh kiện ảo (ESP32, cảm biến).

libraries.txt: Chứa danh sách các thư viện cần thiết để biên dịch dự án.

2. Các bước triển khai mô phỏng (Áp dụng chung cho cả 2 kịch bản)

Bước 1: Chuẩn bị môi trường Wokwi

Mở trình duyệt web và truy cập vào nền tảng mô phỏng: <https://wokwi.com>.

Chọn tạo một dự án mới từ trang chủ (New Project -> ESP32).

Bước 2: Nạp cấu hình môi trường ảo

Trên giao diện soạn thảo của Wokwi, mở thẻ `diagram.json`.

Mở tệp `diagram.json` tương ứng trong thư mục kịch bản, sao chép toàn bộ nội dung và dán đè vào thẻ vừa mở trên web. Sơ đồ mạch mô phỏng sẽ tự động được cập nhật.

Bước 3: Khai báo thư viện mạng

Chuyển sang thẻ Library Manager (hoặc mở thẻ `libraries.txt` trên giao diện Wokwi).

Đảm bảo khai báo đầy đủ các thư viện được liệt kê trong tệp `libraries.txt` của kịch bản (ví dụ: PubSubClient, DHT sensor library...).

Bước 4: Nạp mã nguồn phần mềm

Mở tệp `sketch.ino` từ thư mục kịch bản bằng bất kỳ trình soạn thảo văn bản nào (Notepad, VSCode).

Sao chép toàn bộ mã nguồn và dán đè vào thẻ `sketch.ino` trên Wokwi.

Bước 5: Khởi chạy và thu thập Log

Nhấn nút Play (màu xanh lá) ở thanh công cụ để nền tảng tiến hành biên dịch (Compile) và chạy mô phỏng.

Mở cửa sổ Serial Monitor (nằm ở góc dưới cùng hoặc bên phải giao diện) để theo dõi luồng thực thi của mã nguồn.

3. Hướng dẫn đối chiếu kết quả (Log Output)

Kiểm chứng Kịch bản 1 (`kichban1-khong-an-toan`):

Quan sát Serial Monitor, bạn sẽ thấy thông báo thiết bị kết nối thành công tới MQTT Broker thông qua cổng mặc định (1883) mà không yêu cầu khởi tạo đường hầm TLS hay khai báo thông tin đăng nhập.

Đánh giá: Kịch bản tái hiện thành công trạng thái không an toàn. Mọi dữ liệu JSON gửi qua mạng ảo đang ở dạng rõ (Plaintext).

Kiểm chứng Kịch bản 2 (`kichban2-da-khac-phuc`):

Trong Serial Monitor, log sẽ thể hiện thiết bị mất thêm một khoảng thời gian ngắn để thực hiện quá trình bắt tay TLS (TLS Handshake).

Hệ thống sẽ ghi nhận thiết lập kết nối tới cổng bảo mật (8883) và bắt buộc truyền thông tin Username/Password.

Đánh giá: Xác nhận mã nguồn đã khắc phục lỗ hổng. Kênh truyền tải đã được mã hóa bảo mật, đảm bảo tính toàn vẹn và ngăn chặn các nguy cơ nghe lén/giả mạo (Sniffing/Spoofing).

Mã tiêu chí	NW04 Không dùng giao thức truyền dữ liệu dạng plaintext cho dữ liệu nhạy cảm
Cách kiểm tra	Subscribe topic bằng client bất kỳ, xem có đọc được payload không
Kết quả Kịch bản 1	Serial Monitor: “[MQTT] Publish (KHONG MA HOA)... {nhiet_do:24.0,do_am:40.0}” đọc được nguyên văn
Trạng thái	Chưa đạt (Kịch bản 1)
Kết quả Kịch bản 2	Serial Monitor: “[MQTT] Dang ket noi qua TLS + xac thuc... OK” payload được mã hoá
Trạng thái	Đạt (Kịch bản 2)
Mình chứng	Hình 5.1 và Hình 5.2 (Mục 5.1-5.2)

Bảng 4.4: Mẫu phiếu kiểm tra đã điền thử (Tiêu chí NW04)

Mức ưu tiên	Ý nghĩa	Thời hạn xử lý
Bắt buộc	Phải xử lý trước khi cho phép go-live (OP05)	Trước go-live
Nên có	Xử lý trong 30 ngày sau triển khai	≤30 ngày
Cải tiến sau	Đưa vào backlog cải tiến	Theo chu kỳ bảo trì

Bảng 4.5: Bảng ưu tiên xử lý lỗi

CHƯƠNG 5. KẾT QUẢ VÀ THẢO LUẬN

5.1. Phân tích Log Kịch bản 1 (Insecure)

Trích xuất từ Serial Monitor trên Wokwi:

```
load:0x3fff0030,len:1156
load:0x40078000,len:11456
ho 0 tail 12 room 4
load:0x40080400,len:2972
entry 0x400805dc
[WiFi] Dang ket noi toi Wokwi-GUEST
.....
[WiFi] Da ket noi, IP: 10.10.0.2
[MQTT] Dang ket noi (KHONG TLS, KHONG AUTH)... OK
[MQTT] Publish (KHONG MA HOA) toi topic 'demo/khongantoan/cambien':
{"nhiet_do":24.0,"do_am":40.0}
```

Hình 5.1. Ảnh chụp Serial Monitor thật từ wokwi.com, Kịch bản 1: kết nối MQTT không TLS, không xác thực, publish plaintext.

Dù kết nối thành công, hệ thống vẫn tồn tại lỗ hổng đáng lo ngại. Việc không có TLS đồng nghĩa toàn bộ dữ liệu JSON di chuyển qua mạng ảo Wokwi-GUEST ở dạng rõ. Tin tặc nếu nghe lén (Sniffing) tại Gateway hoàn toàn đọc được dữ liệu này. Hơn thế, việc thiếu xác thực mở ra rủi ro giả mạo thiết bị (Spoofing) để bơm dữ liệu rác.

5.2. Phân tích Log Kịch bản 2 (Secure)

Trích xuất từ Serial Monitor trên Wokwi:

```
load:0x40080400,len:2972
entry 0x400805dc
[WiFi] Dang ket noi toi Wokwi-GUEST
.....
[WiFi] Da ket noi, IP: 10.10.0.2
[MQTT] Dang ket noi qua TLS + xac thuc... OK
[MQTT] Publish (TLS + AUTH) toi topic 'demo/dakhacphuc/cambien':
{"nhiet_do":24.0,"do_am":40.0}
[MQTT] Publish (TLS + AUTH) toi topic 'demo/dakhacphuc/cambien':
{"nhiet_do":24.0,"do_am":40.0}
[MQTT] Dang ket noi qua TLS + xac thuc... OK
[MQTT] Publish (TLS + AUTH) toi topic 'demo/dakhacphuc/cambien':
{"nhiet_do":24.0,"do_am":40.0}
[MQTT] Dang ket noi qua TLS + xac thuc... OK
[MQTT] Publish (TLS + AUTH) toi topic 'demo/dakhacphuc/cambien':
{"nhiet_do":24.0,"do_am":40.0}
```

Hình 5.2. Ảnh chụp Serial Monitor thật từ wokwi.com, Kịch bản 2: kết nối MQTT qua TLS + xác thực, publish lặp lại ổn định.

Độ trễ kết nối ban đầu tăng nhẹ do thiết bị tốn chu kỳ CPU cho quá trình TLS Handshake. Tuy nhiên, luồng giao tiếp TLS + AUTH giúp gói tin chứa chuỗi JSON bị biến đổi thành chuỗi byte mã hóa trước khi rời khỏi ESP32. Cơ chế Authentication xác minh thành công thiết bị là hợp lệ, ngăn chặn các Client ID giả mạo.

5.3. Bảng tổng hợp kết quả theo tiêu chí

Mã	Kỳ vọng (tiêu chí)	Kết quả thực tế	Đạt/Chưa đạt
FW01	Không còn tài khoản/mật khẩu mặc định của nhà sản xuất sau triển khai	Kịch bản 1, broker cho phép anonymous. Chưa đạt (Mục 5.1)	Chưa đạt
FW02	Không hardcode tài khoản/mật khẩu/API key trong mã nguồn/firmware	sketch.ino Kịch bản 1 khai báo MQTT_USER/PASS trực tiếp. Chưa đạt	Chưa đạt
FW03	Không hardcode khoá mã hoá/private key dùng chung toàn dòng sản phẩm	không phát sinh trong 2 kịch bản (không dùng chứng chỉ client). N/A	Một phần
NW02	Toàn bộ traffic dữ liệu nhạy cảm được mã hoá (TLS/DTLS)	Chưa đạt (cổng 1883) / Đạt (cổng 8883 TLS). Mục 5.1-5.2	Chưa đạt
NW04	Không dùng giao thức truyền dữ liệu ở dạng plaintext cho dữ liệu nhạy cảm	Chưa đạt (Kịch bản 1) / Đạt (Kịch bản 2). Mục 5.1-5.2	Chưa đạt
PR01	Kết nối MQTT bắt buộc xác thực, không cho phép anonymous	Chưa đạt (Kịch bản 1) / Đạt (Kịch bản 2). Mục 5.1-5.2	Chưa đạt
PR02	Chứng chỉ TLS của broker/server được client xác minh (không tắt kiểm tra CA)	Kịch bản 2 dùng setInsecure(). Chưa đạt đầy đủ, chỉ chấp nhận trong môi trường lab (Mục 5.4)	Chưa đạt
DT02	Có chính sách thu thập dữ liệu tối thiểu (data minimization)	demo chỉ gửi nhiệt độ/độ ẩm giả lập Đạt ở mức nguyên tắc thiết kế	Đạt
DT05	Khoá mã hoá được quản lý qua KMS/HSM hoặc provisioning an toàn, không đặt cứng trong file cấu hình tĩnh	MQTT_USER/PASS trong sketch.ino là hằng số tĩnh ở cả 2 kịch bản Chưa đạt chuẩn production	Chưa đạt
OP02	Có giám sát/log tập trung cho kết nối và lỗi xác thực bất thường	log broker cục bộ trong lab dùng làm minh họa tối thiểu (Mục 5.1-5.2)	Một phần
OP05	Có phiếu go/no-go trước triển khai; không triển khai khi còn tiêu chí Bắt buộc ở trạng thái Chưa đạt	áp dụng trực tiếp xem khuyến nghị go/no-go ở Mục 5.3	Một phần

Bảng 5.1: Bảng tổng hợp kết quả đánh giá theo từng tiêu chí

5.4. Đối chiếu mục tiêu (Mục 1.3)

Mục tiêu	Mức hoàn thành
MT-01	Đạt: 37 tiêu chí/7 nhóm (Bảng 4.2), vượt yêu cầu tối thiểu 35

MT-02	Đạt: phiếu mẫu đã điền bằng dữ liệu thật (Mục 4.4)
MT-03	Đạt: hướng dẫn sử dụng tại Mục 4.4
MT-04	Đạt: bảng ưu tiên 3 mức tại Mục 4.4
MT-05	Đạt: 11/37 $\approx$ 30% tiêu chí kiểm chứng thật (Mục 5.1-5.3)

Bảng 5.2: Bảng đối chiếu mức độ hoàn thành mục tiêu

5.5. Hạn chế

Chỉ 11/37 tiêu chí ($\sim 30\%$) có kiểm chứng thật; nhóm Phần cứng và API/Cloud chưa có minh chứng thực nghiệm.

Kịch bản 2 dùng `espClient.setInsecure()`; tiêu chí PR02 (xác minh CA hợp lệ) vẫn Chưa đạt đầy đủ.

MQTT_USER/PASS vẫn là hằng số tĩnh trong mã nguồn ở cả 2 kịch bản (DT05 Chưa đạt).

Chưa đo lường được hiệu năng (CPU/RAM/độ trễ) trên ESP32 vật lý thật khi bật TLS.

CHƯƠNG 6. ĐÁNH GIÁ BẢO MẬT

6.1. Tài sản và dữ liệu

Tài sản/dữ liệu	Mức quan trọng	Yêu cầu C-I-A
Thông tin xác thực (WiFi/MQTT credentials)	Cao	Confidentiality, Integrity
Dữ liệu cảm biến (nhiệt độ, độ ẩm)	Trung bình	Confidentiality
Tính toàn vẹn kết nối thiết bị (chống giả mạo)	Cao	Integrity, Availability

Bảng 6.1: Phân loại mức độ quan trọng của tài sản và dữ liệu

6.2. Mối đe dọa và lỗ hổng (T-0 -> T-06)

ID	Tài sản	Đe dọa	Lỗ hổng	Tác động	Nguồn
T-01	Dữ liệu cảm biến, thông tin xác thực	Nghe lén (Sniffing)	Truyền plaintext qua cổng 1883 (NW02/NW04)	Lộ dữ liệu cảm biến và có thể suy ra hành vi vận hành	Log Wokwi thật, Hình 5.1
T-02	Quyền publish/subscribe trên broker	Giả mạo thiết bị (Spoofing)	Broker chấp nhận kết nối anonymous (FW01/PR01)	Kẻ tấn công giả danh thiết bị gửi dữ liệu rác hoặc chiếm topic	Log Wokwi thật, Hình 5.1
T-03	Thông tin xác thực MQTT	Lộ thông tin xác thực qua mã nguồn	MQTT_USER/PASS là hằng số tĩnh trong sketch.ino (FW02/DT05)	Bất kỳ ai đọc được mã nguồn đều lấy được tài khoản thật	Rà soát mã nguồn thật (sketch.ino cả 2 kịch bản)
T-04	Kênh TLS giữa thiết bị và broker	Tấn công trung gian (MITM)	Client dùng espClient.setInsecure(), bỏ qua xác minh CA (PR02)	Kẻ tấn công có thể giả mạo broker trong cùng mạng để đọc/sửa dữ liệu dù đã có TLS	Rà soát mã nguồn thật (Kịch bản 2)
T-05	Phạm vi truy cập topic MQTT	Leo thang truy cập giữa các thiết bị	Chỉ dùng 1 tài khoản dùng chung, không có ACL theo topic (PR03)	Một thiết bị bị xâm nhập có thể đọc/ghi dữ liệu của thiết bị khác	Rà soát cấu hình broker/mã nguồn (không kiểm thử động)
T-06	Khả năng phát hiện sự cố	Sự cố không	Chỉ có log broker cục bộ trong lab, chưa có	Kéo dài thời gian phát hiện	Quan sát trực tiếp

		được phát hiện kịp thời	giám sát tập trung (OP02)	và xử lý khi có tấn công thật	lab Mosquito (Mục 5.1- 5.2)
--	--	-------------------------------	------------------------------	-------------------------------------	--------------------------------------

Bảng 6.2: Các mối đe dọa và lỗ hổng xác định (T-01 đến T-06)

6.3. Ma trận rủi ro (R-01...R-06)

Điểm rủi ro = Khả năng (1-5) × Tác động (1-5); 1-5 Thấp, 6-10 Trung bình, 11-15 Cao, 16-25 Nghiêm trọng.

ID	KN	TĐ	Điểm	Mức	Biện pháp	Rủi ro còn lại
R-01	5	4	20	Nghiêm trọng	Chuyển WiFiClient -> WiFiClientSecure, cổng 8883 (TLS)	Thấp-đã kiểm chứng qua Hình 5.2
R-02	4	4	16	Nghiêm trọng	Bắt buộc username/password trong mqtt.connect()	Thấp-đã kiểm chứng qua Hình 5.2
R-03	4	5	20	Nghiêm trọng	Chuyển sang NVS mã hoá hoặc Secure Element khi có thiết bị thật	Cao-CHƯA khắc phục trong phạm vi đề tài
R-04	3	4	12	Cao	Dùng chứng chỉ CA hợp lệ, tiến tới mutual TLS (mTLS)	Trung bình - CHƯA khắc phục trong phạm vi đề tài
R-05	3	3	9	Trung bình	Cấu hình ACL theo topic cho từng thiết bị	Trung bình - chưa kiểm thử động
R-06	3	3	9	Trung bình	Triển khai log tập trung (SIEM/ELK) khi lên production	Trung bình - chỉ minh hoạ tối thiểu trong lab

Bảng 6.3: Ma trận đánh giá rủi ro (R-01 đến R-06)

6.4. Ưu tiên biện pháp

Biện pháp	Ai làm	Chi phí/độ khó	Cách xác minh
Chuyển WiFiClient -> WiFiClientSecure, cổng 8883 (TLS)	Người triển khai firmware	Thấp (đổi ~5 dòng code)	Bắt lại gói tin, xem payload còn đọc được không
Bắt buộc username/password trong mqtt.connect()	Người triển khai firmware	Thấp	Thử connect() không kèm user/pass, kỳ vọng bị từ chối

Chuyển sang NVS mã hoá hoặc Secure Element khi có thiết bị thật	Người triển khai (hướng phát triển)	Trung bình - cần thiết bị vật lý	strings trên firmware .bin, kỳ vọng không thấy chuỗi mật khẩu
Dùng chứng chỉ CA hợp lệ, tiến tới mutual TLS (mTLS)	Người triển khai (hướng phát triển)	Trung bình - cần hạ tầng CA	Thử kết nối tới broker giả mạo chứng chỉ sai, kỳ vọng bị từ chối
Cấu hình ACL theo topic cho từng thiết bị	Người quản trị broker	Thấp - cấu hình broker	Thử publish/subscribe ngoài phạm vi được cấp, kỳ vọng bị từ chối
Triển khai log tập trung (SIEM/ELK) khi lên production	Đội vận hành	Cao - cần hạ tầng giám sát	Kiểm tra có cảnh báo khi phát hiện kết nối bất thường

Bảng 6.4: Bảng ưu tiên các biện pháp xử lý và cách xác minh

6.5. Đánh giá sau xử lý

Sau khi áp dụng 2 biện pháp đã kiểm chứng thật (TLS + xác thực), R-01 và R-02 giảm từ mức Cao xuống Thấp được xác nhận trực tiếp qua Hình 5.2. R-03 (credentials hardcoded) và R-04 (setInsecure()) CHƯA được khắc phục trong phạm vi đề tài, vẫn ở mức Cao/Trung bình đây là rủi ro còn tồn tại thật, cần xử lý ở giai đoạn phát triển tiếp theo (Mục 7.2). R-05, R-06 chưa kiểm thử động, chỉ đánh giá qua rà soát cấu hình/mã nguồn.

CHƯƠNG 7. KẾT LUẬN

7.1. Kết luận

Tiểu luận “Checklist kiểm tra bảo mật thiết bị IoT trước triển khai” đã hoàn thành trọn vẹn các mục tiêu đề ra, cung cấp một quy trình đánh giá rủi ro tinh gọn và thực dụng cho lớp phần mềm và giao thức mạng. Thông qua việc đối chiếu hai kịch bản trên nền tảng Wokwi, báo cáo đã trực quan hóa thành công sự nguy hiểm của các cấu hình mặc định (truyền tải dữ liệu Plaintext qua cổng 1883 và không xác thực).

Điểm sáng của bài là đã chứng minh được tính hiệu quả tức thời của Checklist. Chỉ bằng các tinh chỉnh trực tiếp vào mã nguồn chuyển đổi sang WiFiClientSecure, cấu hình cổng 8883 (MQTTs) và ép buộc xác thực Username/Password hệ thống đã thiết lập được luồng truyền tải mã hóa TLS. Điều này cho thấy việc rà soát chặt chẽ cấu hình mã nguồn ngay từ giai đoạn phát triển (Code Review) là biện pháp tối ưu và tiết kiệm chi phí nhưng có tác dụng đáng kể trong việc giảm rủi ro nghe lén (Sniffing) và giả mạo (Spoofing) trên môi trường IoT.

7.2. Hướng phát triển

Từ nền tảng lý thuyết và thực nghiệm của bài, các hướng nghiên cứu tiếp theo có thể được mở rộng:

Tích hợp tự động hóa vào CI/CD: Áp dụng các công cụ phân tích tĩnh chuyên dụng cho firmware (như EMBA, firmwalker thuộc chuẩn OWASP FSTMT) để tự động phát hiện các đoạn code gọi hàm mạng không an toàn trước khi biên dịch.

Nâng cấp cơ chế xác thực mạng: Chuyển đổi từ việc xác thực cơ bản (User/Password) sang cơ chế xác thực hai chiều (Mutual TLS / mTLS) bằng chứng chỉ số X.509 để nâng cao tối đa độ an toàn cho giao thức MQTT.

Bảo mật lưu trữ trên phần cứng thực tế: Đưa kịch bản đã khắc phục lên thiết bị ESP32 vật lý, đồng thời nghiên cứu triển khai tính năng mã hóa vùng nhớ NVS (Non-Volatile Storage) để lưu trữ thông tin mạng và tài khoản thay vì ghi trực tiếp dưới dạng văn bản trong file mã nguồn.

TÀI LIỆU THAM KHẢO

- [1] OWASP. (n.d.). IoT Security Verification Standard (ISVS). Truy cập ngày 25/07/2026, từ <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>
- [2] OWASP. (n.d.). IoT Security Testing Guide (ISTG). Truy cập ngày 25/07/2026, từ <https://github.com/OWASP/owasp-istg>
- [3] OWASP. (n.d.). Firmware Security Testing Methodology (FSTM). Truy cập ngày 25/07/2026, từ <https://github.com/scriptingxss/owasp-fstm>
- [4] OWASP. (n.d.). OWASP Internet of Things Project — IoT Top 10. Truy cập ngày 25/07/2026, từ <https://github.com/OWASP/www-project-internet-of-things>
- [5] ETSI. (2024). ETSI EN 303 645 V3.1.3 - Cyber Security for Consumer Internet of Things. Truy cập từ https://www.etsi.org/deliver/etsi_en/303600_303699/303645/03.01.03_60/en_303645v030103p.pdf
- [6] NIST. (2020). NISTIR 8259A - IoT Device Cybersecurity Capability Core Baseline. Truy cập từ <https://nvlpubs.nist.gov/nistpubs/ir/2020/NIST.IR.8259A.pdf>
- [7] Bursztein, E. (Cloudflare). (2017, December 14). Inside the Infamous Mirai IoT Botnet: A Retrospective Analysis. Truy cập từ <https://blog.cloudflare.com/inside-mirai-the-infamous-iot-botnet-a-retrospective-analysis>
- [8] CISA. (2016, October 14). Heightened DDoS Threat Posed by Mirai and Other Botnets. Truy cập từ <https://www.cisa.gov/news-events/alerts/2016/10/14/heightened-ddos-threat-posed-mirai-and-other-botnets>
- [9] Wokwi. (n.d.). ESP32/DHT22 Simulator. Truy cập ngày 25/07/2026, từ <https://wokwi.com/>
- [10] Eclipse Mosquitto. (n.d.). MQTT Broker. Truy cập từ <https://mosquitto.org/>

